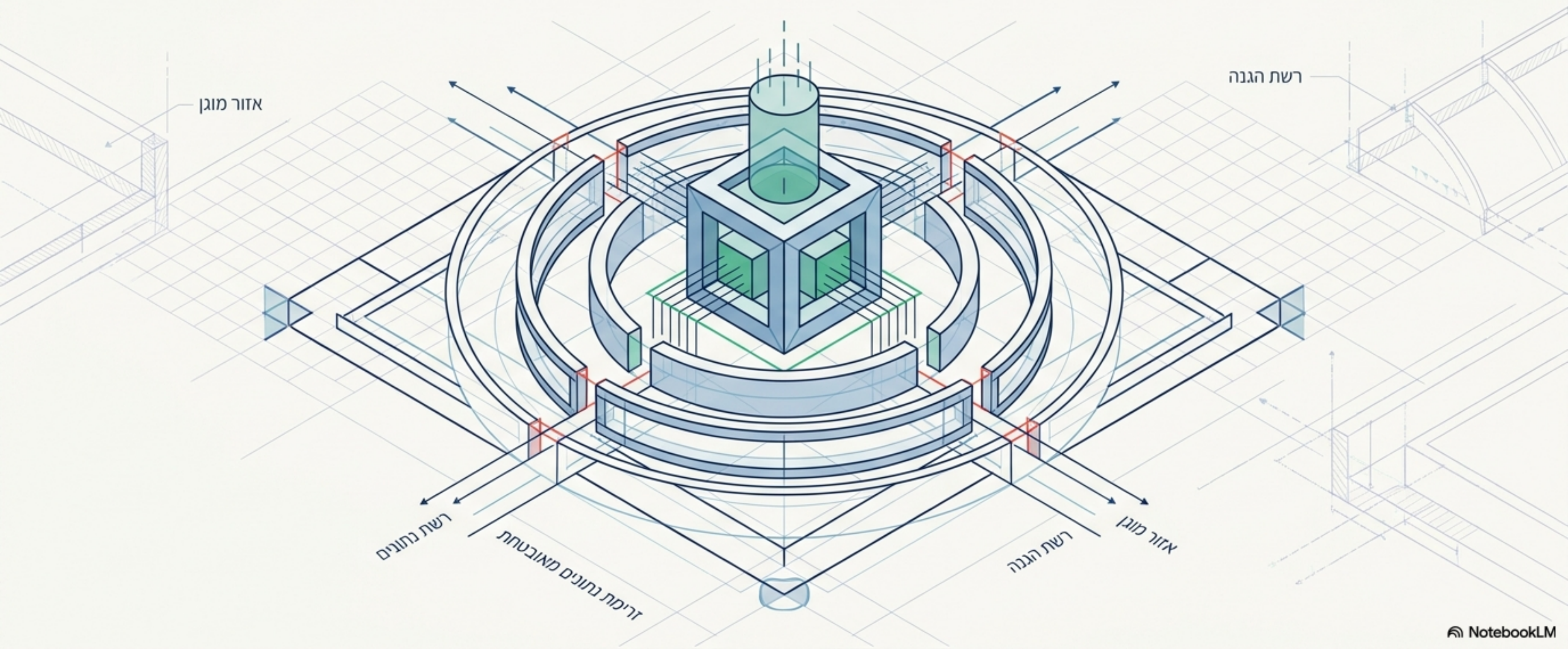


אבטחת מידע: ארכיטקטורה של אמון דיגיטלי

סקירת מנהלים והיכרות עם יסודות ההגנה במרחב הקיברנטי



היעדים המרכזיים: משולש CIA-ה

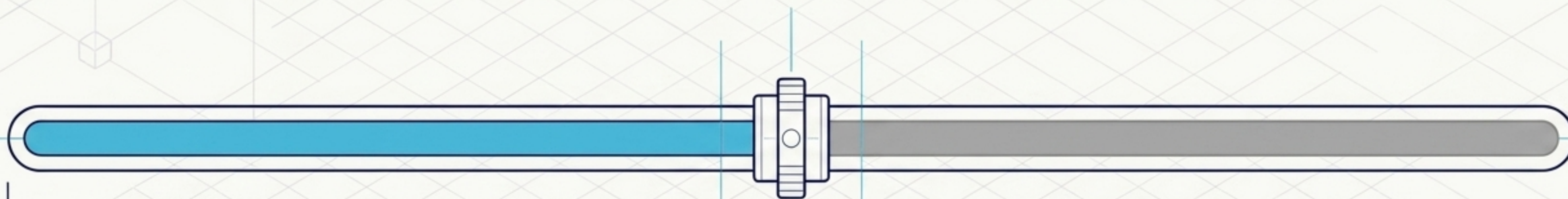
סודיות (Confidentiality)
הגבלת גישה וחשיפה לגורמים מורשים
בלבד. שמירה על פרטיות וקניין רוחני.

זמינות (Availability)
שמירה על יעילות וזמינות הגישה
למידע בכל זמן נתון, חרף תקלות או
תקיפות.

שלמות (Integrity)
הגנה מפני שינוי זדוני או השמדה.
הבטחת אמינות ואי-התכחשות.



הדילמה התמידית: פרדוקס הנוחות והביטחון



מחשב מנותק לחלוטין.
ללא רשת, מקלדת, עכבר או צג.
(אבטחה מוחלטת, חוסר שמישות).



**גישה גלובלית ללא
סיסמאות מכל מכשיר.**
(נוחות מוחלטת, אפס אבטחה).



מחיר הכישלון: אובדן אמון.
כאשר מאגרי חברה נפרצים, הלקוחות הופכים לקורבן. הנזק
התדמיתי והעסקי עולה לאין שיעור על עלות מנגנוני ההגנה.

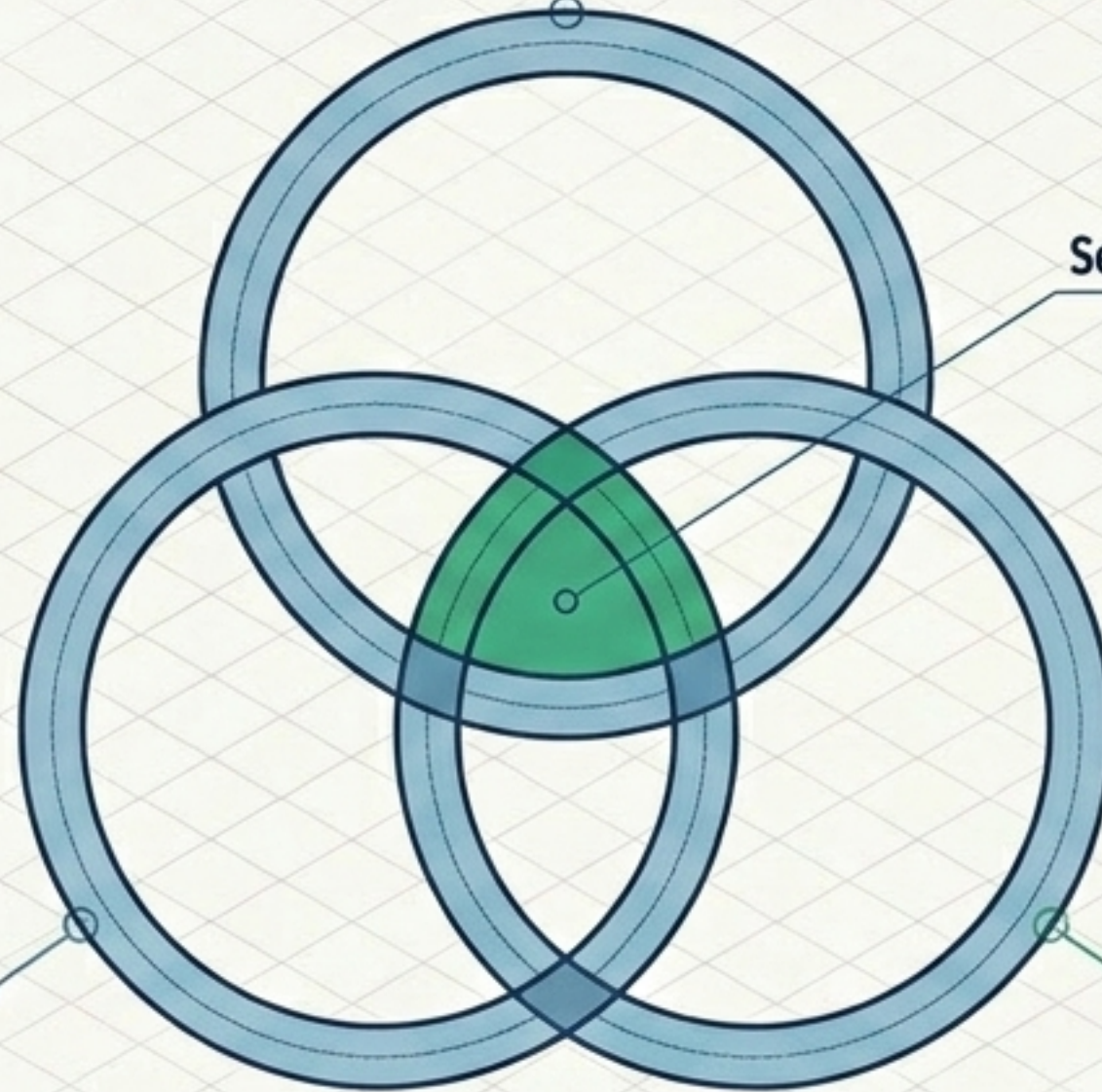


מוקדי הסיכון: משולש ה-PPT

אנשים (People)

החוליה החלשה. משתמשים עושים שגיאות, נופלים קורבן להנדסה חברתית ויוצרים פרצות בלתי מכוונות.

Secure State



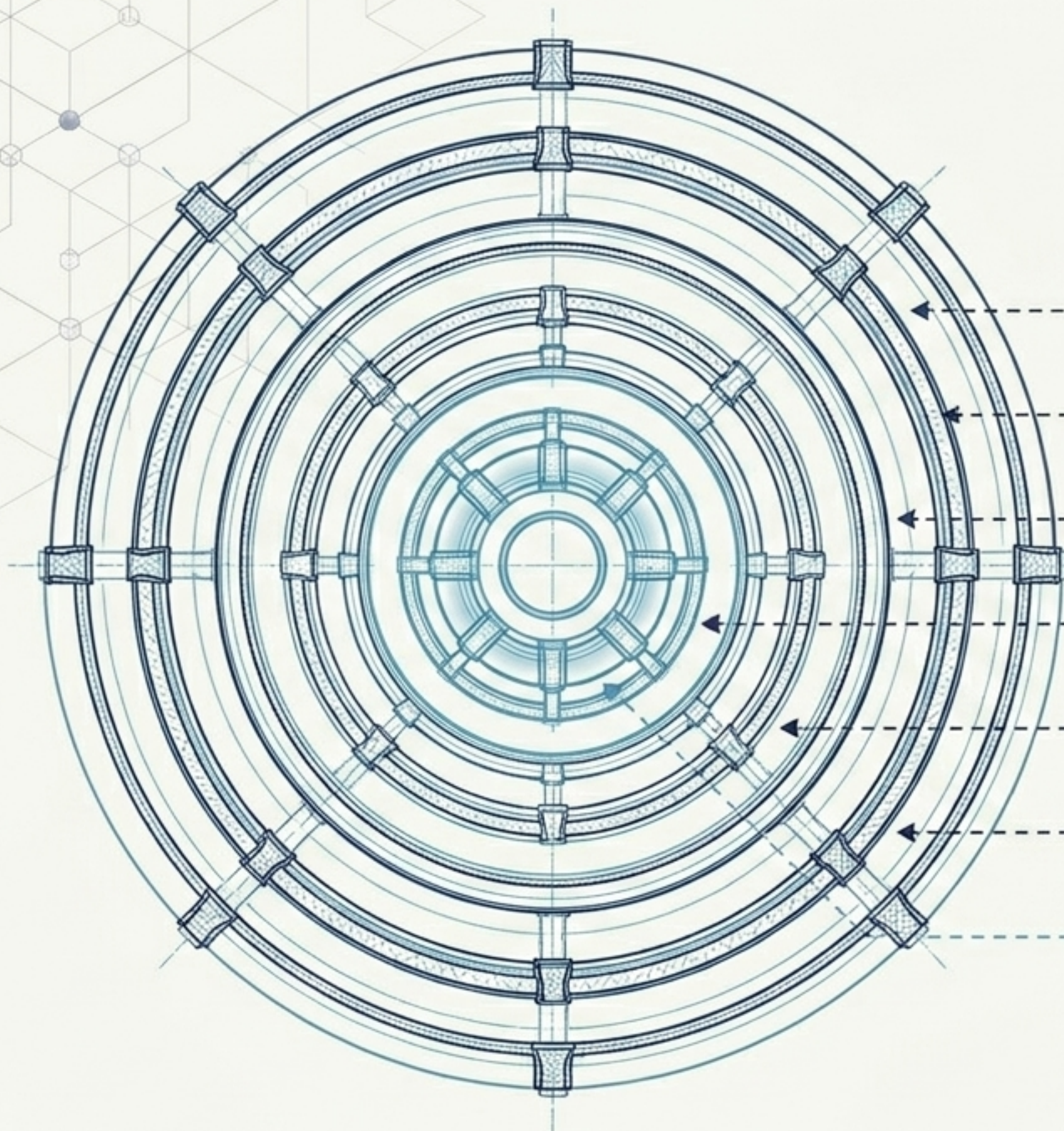
טכנולוגיות (Technology)

מערכות חומרה, תוכנה ותקשורת. הכלים הטכניים המיישמים את ההגנה בפועל.

תהליכים (Process)

תכנון נכון, בקורות מוגדרות וזיהוי מוקדם. נועדו לצמצם את מידת הנזק הנגרם משגיאת אנוש.

האסטרטגיה: הגנה לעומק (Defense in Depth)



1. שכבת מדיניות ונהלים (Policy)

2. שכבת הגנה פיזית (Physical)

3. שכבת תקשורת חיצונית (WAN/Perimeter)

4. שכבת תקשורת פנימית (LAN)

5. שכבת תחנת משתמש (Endpoint)

6. שכבת יישומים (Application)

7. נתונים (Data Core)

זירות הלחימה של המרחב הקיברנטי

מכשירים ניידים (BYOD)

התמודדות עם מכשירים היוצאים מגבולות הארגון ומתחברים למערכות הליבה.



אבטחת יישומים ותוכנה

הגנה על קוד המקור. תיקון חורי אבטחה באפליקציות מקומיות ומניעת קוד זדוני.



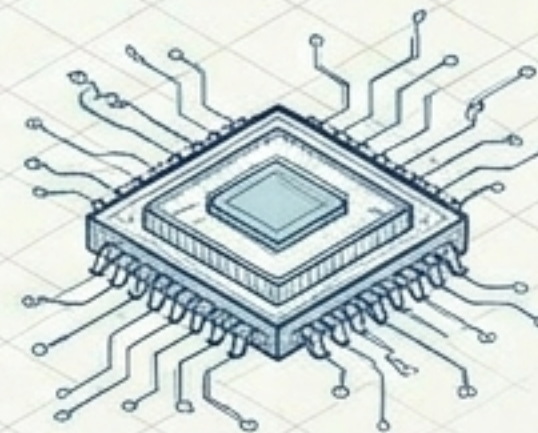
תשתיות אינטרנט עולמיות

התמודדות עם פרוטוקולים ומרכזי מידע חיצוניים שאינם בשליטת הארגון.

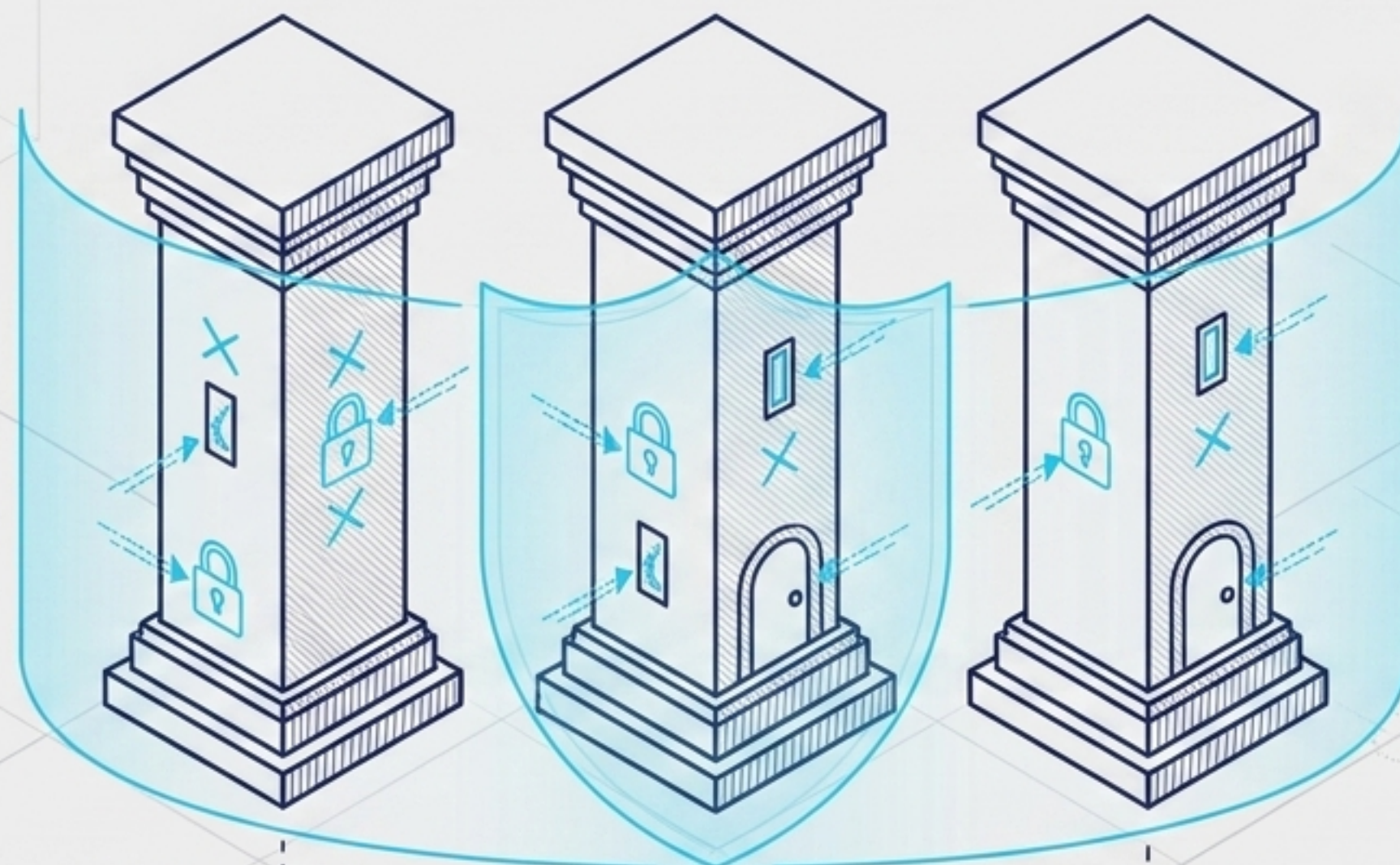


חומרה וקושחה

התגוננות מפני תקיפות מורכבות (לעיתים בחסות מדינה - Warfare Cyber) ברמת השבב.



הקשחת הליבה (System Hardening)



מסדי נתונים

צמצום אופציות 'פתוחות מדי' באמצעות נהלים וטכנולוגיה, כך שהמידע יהיה זמין אך ורק לצרכים המקוריים של הארגון.

רכיבי תקשורת (OSI)

הגבלת השטח החשוף לתקיפה בנתבים, מתגים ופרוטוקולי תקשורת למינימום הנדרש לתפעול תקין.

מערכות הפעלה

אטימת פגיעות במערכות Windows/Linux על ידי סגירת שירותים מיותרים ושימוש בכלי עזר מקשיחים.

ממשל אבטחת מידע וניהול סיכונים



אנטומיה של תקיפת סייבר

ניקיון (House Keeping)

מחיקת עקבות לאחר
השגת המטרה.

חדירה (Penetration)

ניצול חולשה וריכוז כלי
תקיפה.

איסוף מודיעין

חקירת היעד מחוץ
למרחב המוגן.

ניטור תעבורה ואנומליות

חיפוש רציף של התנהגות חריגה
וזיהוי פצחנות (Hacking) בזמן אמת.

מנגנון 1: הזדהות ואימות זהות (Authentication)



Factor 1 + Factor 2 = הזדהות חזקה (Strong Auth)

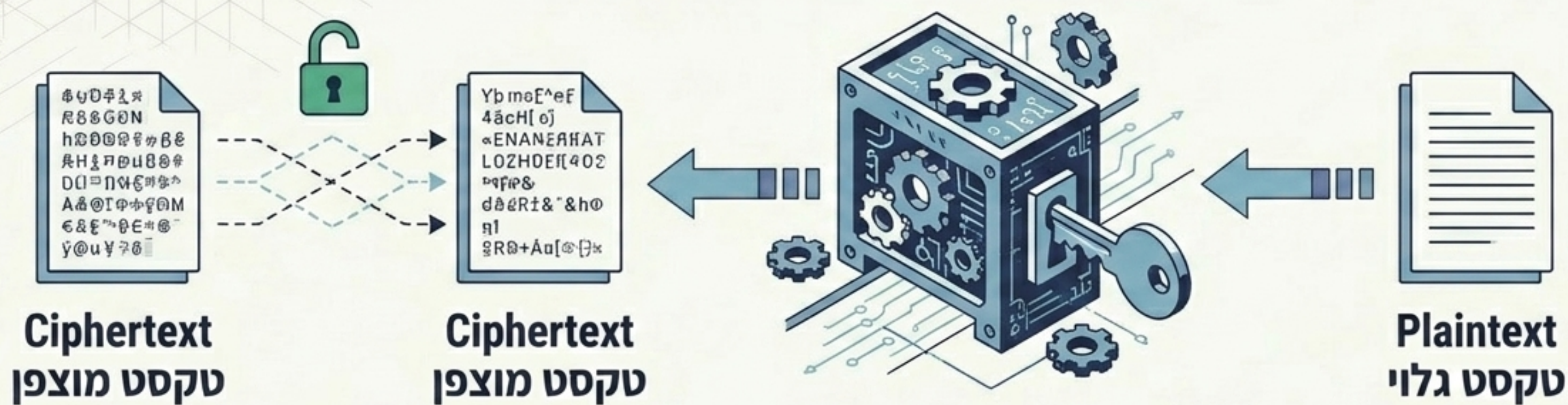
מנגנון 2: בקרת הרשאות (Authorization)



העיקרון: לאחר ההיזדהות, המערכת נדרשת לקשר בין המשתמש לבין הפעולות המותרות לו (יצירה, קריאה, מחיקה או שינוי).

דוגמת ויקיפדיה: מערכת המאפשרת לכל גולש אנונימי לקרוא או לערוך, אך שומרת פעולות של הגנת דפים ומחיקתם למפעילי מערכת בעלי הרשאה ספציפית בלבד.

מנגנון 3: קריפטוגרפיה ותשתית מפתחות



אימות ושלמות

שימוש בחתימה דיגיטלית
ופונקציות גיבוב להבטחת
אי-התכחשות.

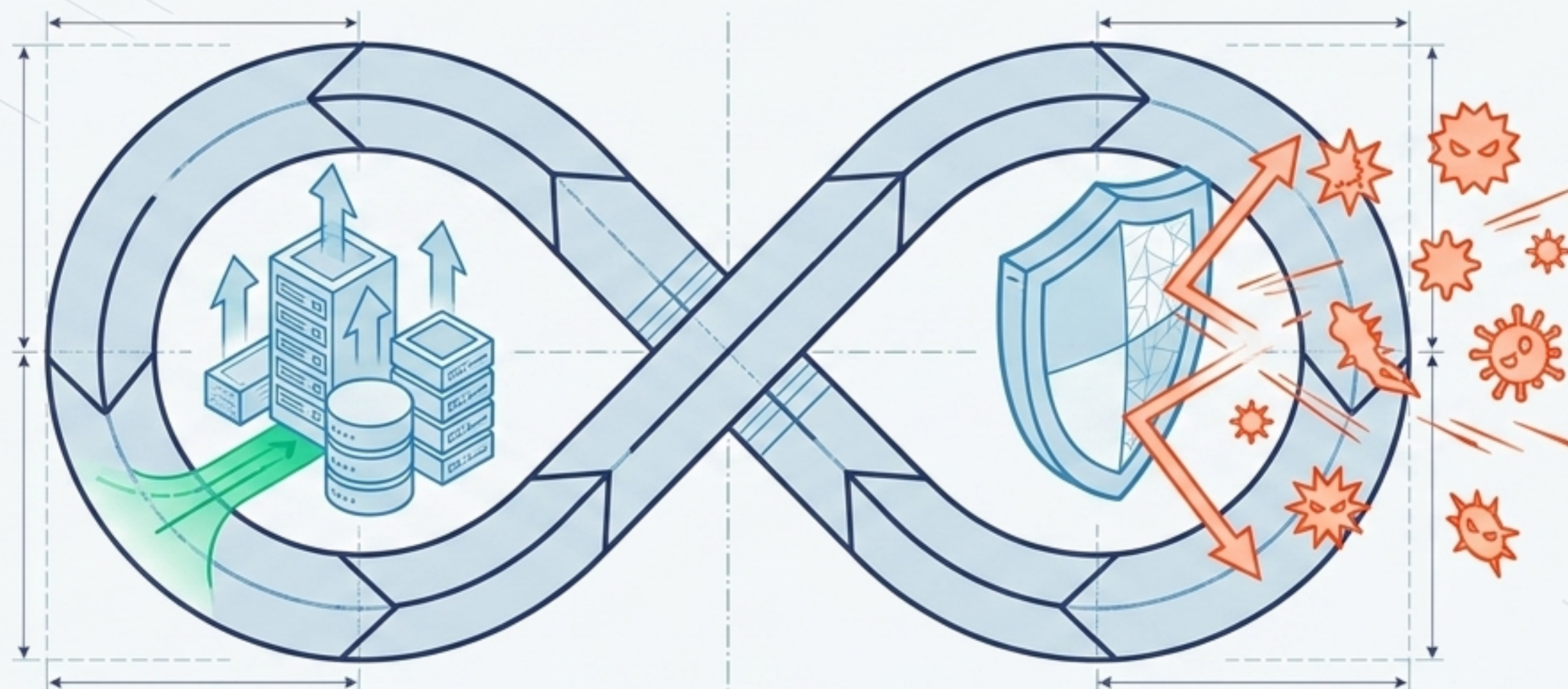
תשתית מפתח ציבורי (PKI)

מערך המאפשר העברה מאובטחת
ותחזוקה של מפתחות הצפנה
ברשת פתוחה.

הצפנה (Encryption)

הפיכת נתונים למצב בלתי
קריא תוך שימוש באלגוריתמים
תקניים (RSA, AES).

מנגנון 4: בלימת נזקות והבטחת המשכיות



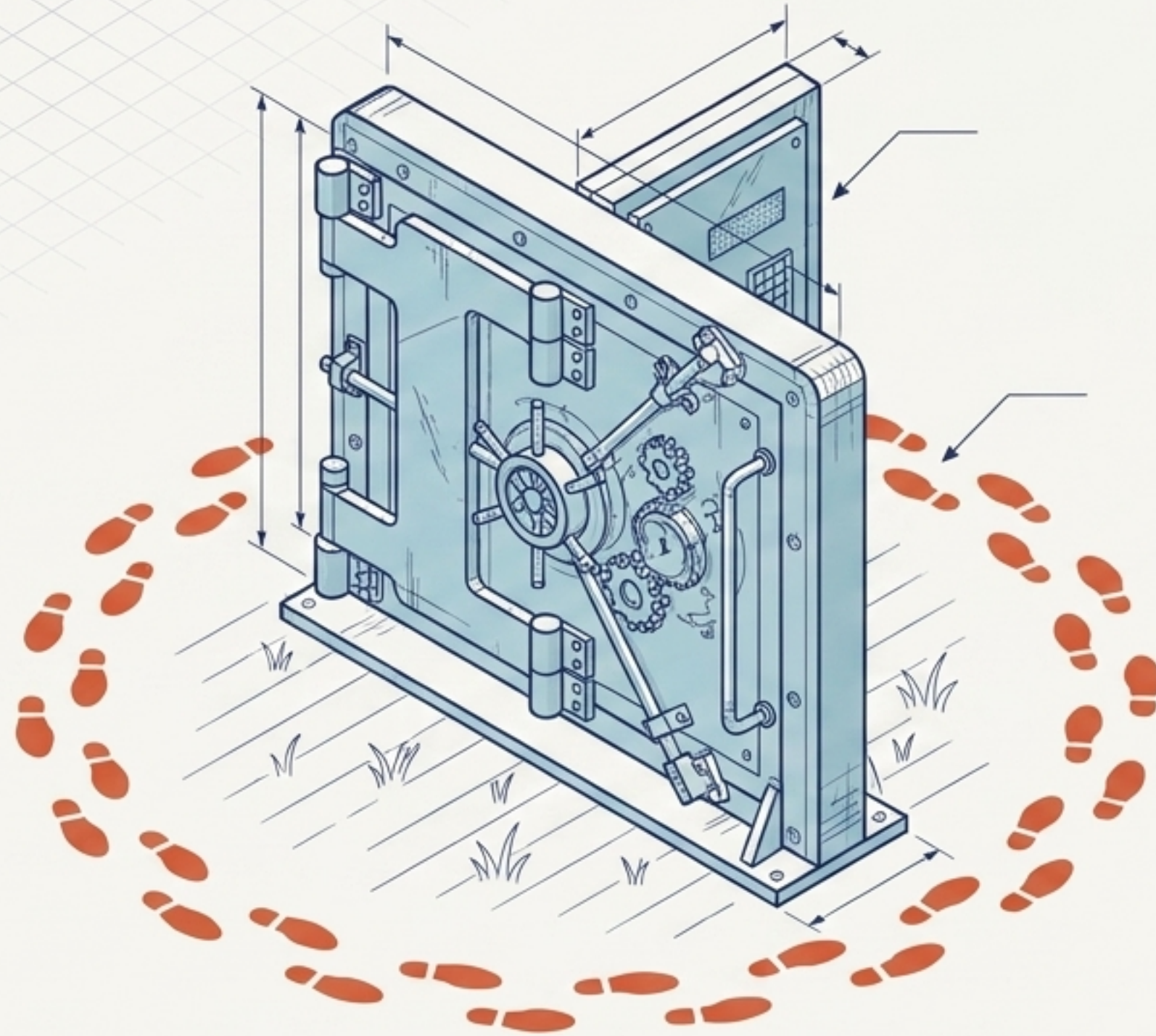
שחזור

גיבוי (Backup) - שמירת עותק נתונים מבודד
המאפשר שחזור מלא במקרה של פגיעה, השחתה
או כופרה, תוך צמצום ההשבתה.

מניעה

חסימת תוכנות מזיקות (וירוסים, סוסים טרויאנים,
רוגלות-Spyware) בעמדת הקצה ובשרתי הנישה
(Gateway) לחיסול ניסיונות גניבת כוח עיבוד או
ריגול.

הגורם האנושי: אבטחת מידע התנהגותית



◀ ככל שאמצעי ההגנה פוגעים בנוחות השימוש, גובר הסיכוי שמשתמשים ינסו לעקוף אותם (למשל: בחירת סיסמאות חלשות או כתיבתן על פתק).

◀ **הנדסה חברתית:** תוקפים מנצלים את טבע האדם במקום לפרוץ קוד.

◀ **הפתרון:** חינוך טכנולוגי בארגון, העלאת מודעות ואיזון קפדני בין רמת אבטחה לחוויית המשתמש.

האקוסיסטם המקצועי של יחידת האבטחה

הנהלה וממשל (Governance)

מנהל אבטחת מידע (CISO),
מומחה GRC, מבקר אבטחת מידע.

הגנה וניטור (Blue Team)

אנליסט במרכז ניטור (SOC),
מומחה התנהגות רשת חריגה,
ארכיטקט אבטחה.

תקיפה ובדיקה (Red Team)

בודק חוסן/חדירות (PT),
מומחה כתיבת נוזקות,
מומחה הנדסה לאחור (Reverse Engineering).



אבטחת מידע אינה רק טכנולוגיה, אלא סימפוניה של אנשים,
תהליכים ומודיעין הפועלים ברציפות.